

Ch1_Enterprise Risk Management

一、What is ERM?

A **systematic, integrated** approach to managing all risk facing an organization.

- systematic: step by step

Identify (是什么) → Evaluate (多少loss) → Manage (all major corporate risks in an integrated framework)

- integrated: 多种方式
 - manage: *controlling or organizing*
-

1. **As a part of corporate strategy** 公司战略

- Strategy – How to do in the future?
- Consideration of **risks** in **strategy selection**
- One way to control **them**

2. **(Them) Factors affecting organizations activities, process and resources**

- ✓ External Factors: Economic change, financial market development, political, legal, technological and demographic environments.
- ✓ Internal Factors: Human error, fraud, systems failure, disrupted production and other risks.

风险来源:

a. External:

- **Economic change** 经济变化: 如通货膨胀 inflation、利率波动 interest rate fluctuations、经济衰退 economic downturns 等
 - 影响企业的**产品定价**、**成本结构**、**消费者购买力**。
- **Financial market development** 金融市场发展: 汇率波动 Exchange rate volatility 、股市波动 stock market fluctuations , 影响企业**融资和投资决策** financing options and investment strategies. 。
 - 影响企业的**融资能力**、**投资策略**、**财务稳定性**。
- **Political / Legal** 政治与法律环境: 政策变动、监管加强, 尤其对**跨国企业** multinational firms 影响显

著。

- **Technological 技术环境**：技术迭代速度快，可能导致产品过时 **obsolete** 或系统安全风险。
- **Demographic environments 人口结构变化**：如老龄化、劳动力结构变化 **Aging populations and workforce shifts**，会影响人力资源战略和市场定位。

b. Internal:

- **Human error 人为错误**：操作失误 **Operational mistakes**
- **Fraud 欺诈行为**：内部舞弊、数据造假，损害企业声誉与合规性
- **System failure: 系统故障**：IT系统宕机、数据丢失
- **Disrupted production 生产中断**：供应链断裂 **chain disruptions**、设备故障 **equipment breakdowns**，导致交付延迟或成本上升
- **其他运营风险**：如文化冲突等

3. Meanings of ERM nowadays

ERM 已从传统的风险控制工具，演变为战略管理的组成部分

- a. Risk viewed in context of business strategy 企业不再孤立地看待风险，而是将其作为战略制定与执行的一部分。
- b. Risk portfolio development 构建风险组合视角
- c. Focus on **critical** risks
- d. Risk **strategy**
- e. Defined risk **responsibilities**
- f. Monitoring & measurement of risks 监控与量化评估

二、Types of RISK

分类标准	说明	示例分类
按影响性质	根据风险带来的后果是正面还是负面	➤ 机会型风险 (Opportunity) ➤ 威胁型风险 (Threat)
按严重程度	根据风险发生后对组织的打击程度	➤ 致命风险 (Killer risks) ➤ 一般风险 (Other perils)

按发生频率与可预测性	是否为高频/低频事件，是否可预测	► 可预测风险（如季节性销售波动） ► 黑天鹅事件（如突发政策变动）
按组织结构影响范围	风险影响的组织层级或部门范围	► 部门特有风险（Department-specific risks） ► 跨职能风险（Cross-functional risk） ► 流程特有风险（Business process unique risks 可能跨部门）
按来源或触发机制	风险来自外部环境还是内部流程	► 外部风险（如市场变化、法规） ► 内部风险（如系统故障、员工失误）

1. Opportunities（机会型）：

Events presenting a **favorable** combination of circumstances giving rise to the chance for beneficial activity. (Covid – 19 ZOOM)

2. Killer risks:

Events presenting an **unfavorable** combination of circumstances leading to hazard or major loss or damage resulting in **permanent ending of operations**

(2008 金融危机 雷曼兄弟 (Lehman Brothers) – 是美国第四大投资银行 破产。

- 其大量持有次级抵押贷款相关资产 (subprime mortgage-backed securities)，在房地产泡沫破裂后，这些资产迅速贬值，导致巨额亏损和流动性危机。

3. Other perils:

Events presenting an **unfavorable** combination of circumstances leading to hazard or loss or damage to leading to disruption of operations with **possible financial loss**.

4. Cross functional risks:

Common risks leading to potential loss of reputation

“跨职能”指的是多个部门、流程或系统之间的协作与互动；企业声誉往往建立在一致性、专业性和客户信任之上。

5. Business process unique risk:

Risk occurring within a **specific operation or process**, such as withdrawal of a particular product for quality reasons.

- 业务流程特有风险是指源于**特定公司**或流程的**特定活动**、方法和内部运作的威胁或漏洞，通常属于非系统性风险（特定公司特有的风险）和运营风险（来自内部流程、人员和系统的风险）

三、Business Risk Types

风险来源角度：

- External Environment
- Business Strategies & Policies
- Business Process Execution
- People
- Analysis & Reporting
- Technology & Data

1. External Environment:

- Competitors
- Legal & regulatory loss – 由于违反法律、法规、监管要求或合同义务而导致的**直接或间接损失**（公众信任↓）
- Customer expectation (eg. delivery time)

2. Business Strategies & Policies:

- Strategy & innovation – 制定发展方向和创新举措（投入新产品，市场接受度低）
- Capital allocation (Money allocation in different department)
- Business 业务/product portfolio – 企业在选择和管理产品线或业务板块时的风险（企业依赖单一产品，一旦市场需求下降，整体营收受影响）
- Organization structure（层级过多、职责不清、沟通障碍）
- Organization policies 企业内部规章制度的制定（如 绩效考核制度不透明 ）

项目	Business Strategy	Planning
----	-------------------	----------

关注点	长期方向、竞争定位、资源配置	战术执行、时间安排、任务分解
层级	战略层 (Why & What)	战术层 (How & When)

3. Business Process Execution 执行业务流程

- Planning – 目标设定/资源安排/时间表制定/etc.
- Process/technology design – 设计合理的业务流程和配套技术架构，以提升效率和可扩展性 (enhance the scale if too much people use it)
- Vendor 供应商/partner合作伙伴 reliance – 对于外部资源的依赖
- Customer satisfaction
- Regulatory compliance & privacy
- Knowledge/ intellectual capital 知识与智力资本流失风险（如， Knowledge gaps caused by employee turnove / Intellectual property and technology leakage ）
- Change integration – 吸收变化，具备适应性和弹性

4. People

- Leadership 领导力风险 (Poor decision-making, lack of vision 远见)
- Skills (Lack of necessary skills, outdated technical capabilities)
- Communication
- Performance incentives 绩效激励 – 激励机制不合理
 - Sales team incentivized solely on short-term revenue 收益，忽视客户长期关系维护。
 - R&D team rewarded based on patent count --> submit low-quality or redundant patents.
 - Unrealistic KPIs lead to data manipulation
- Fraud & abuse

5. Analysis & Reporting 分析与报告相关风险

Analysis – exploring data to **extract meaningful insights** 洞察 that support decisionn –making. => 解读数据（洞察、建议、预测）

Reporting – 数据 -> information summaries. => 呈现数据（图表、表格、摘要）

- Performance management – 通过**数据分析**来监控和评估组织绩效
- Budgeting planning

- External reporting & disclosure
 - 企业向外部利益相关者（如投资者、监管机构、公众）披露财务、运营或合规信息的过程。
- Pricing / margin 利润 – 据分析来评估定价效果
- Market intelligence 市场情报 – 数据收集不全面

6. Technology & Data

- Technology infrastructure 基础设施 数据中心断电 data center outage
 - Data relevance & integrity 相关性与完整性
 - Data processing integrity – 处理过程中， 避免丢失或篡改 (A formatting error)
 - Technology reliability & recovery
 - An e-commerce platform crashes during a promotion and takes hours to recover, resulting in lost orders.
 - IT security
-

四、Risk Strategy

风险战略 guidelines:

- *Organization & responsibilities;*
- *Organization risk attitude ;*
- *Ownership for specific risks;*
- *Methods to be used to each planning level to deal with risk;*
- *Peer reviewing and benchmarking;*
- *Encouragement of proactive risk reporting ;*
- *Criteria for risk assessment and definition of critical risks;*
- *Encouraging effective communication of risks.*

Benchmarking – 客观数据

Peer reviewing – 专家 / 同行主观

五、A framework for risk management

1. 识别风险 + 明确目标

- Step 1: **Establish** a risk management framework
 - Identifying, evaluating, exploiting, financing and monitoring **risk events** 识别、评估、利用、融资与监控风险事件
 - Establishment of **strategic objectives**
 - Top management is responsible to **direct** and set **controls**
高层管理负责制定方向与控制机制

2. 理解高层需求 + 分析/评估 风险可能性、影响

- Step 2: Risk requirements
 - Understand organizational internal and external key **stakeholders** and **their objectives and strategies** for the risks
 - Assessment, to include **analysis** and evaluation
分析风险发生的可能性与影响，评价其严重程度。

3. 风险信息传播路径 + 技术支持/人员配置认知

- Step 3: Identify the **flow of information**
 - **Report** the threats and opportunities 例如，客服投诉信息聚客服系统流向质量管理部门，再反馈至产品团队。
 - Accurate and details **flowchart** of information flow 明确信息从哪里来、如何处理、传递到哪里
 - Software and hardware needed by each department
 - Identification of skilled personnel required to operation them
识别操作所需的技术人才

4. 可行性分析，是否值得投入资源

- Step 4: **Feasibility** analysis
 - Identify the alternative means of obtaining risk management software
 - Estimate the **cost** of proposed system
 - Consider the ability to cope with increased work load
考虑应对工作量增加的能力 工作负荷

5. 做决定 – 买/租

- Step 5: Buy or lease
 - **Make decisions** after the feasibility analysis
 - Companies offers customized packages for specific aspects of risk management : financial management, insurance risk and project risk etc.

六、Risk by Level 商业风险5个层级

控制难度角度：

- Top level: Strategy business risk
- 2nd level: Market/ Business environment risk
- 3rd level: Financial performance risk
- 4th level: Operational risk
- 5th level: Compliance and financial reporting risk

战略层风险 / Strategy Risk

- 涉及企业的长期方向、竞争定位、并购决策等。

市场与环境风险 / Market & Business Environment Risk

- 来自外部环境的变化，如经济波动、政策调整、行业竞争等。

财务表现风险 / Financial Performance Risk

- 涉及收入、成本、利润、现金流等财务指标的波动。

运营风险 / Operational Risk

- 与日常业务流程、系统、人员、技术相关的问题。

合规与财务报告风险 / Compliance & Reporting Risk

- 涉及法律法规遵守、财务报表准确性、审计合规性等。

思考角度：影响范围/发生频率

Assignment

- How do we identify each type of risk that you learned from this chapter? Analysis for each type of risk for providing the examples in the information technology industry.

From the influences:

- Favorable (Positive) → Opportunities risk
- Unfavorable (Negative) – Whether or not cause permanent ending
 - Yes → Killer risks
 - No → Other perils

The department involved in – Multiple department → Cross functional risk

General/Specific Process – Specific → Business process Unique risk

IT industry

- Opportunities risk:
 - Lumen – American company in Telecom and technique – In 2024, Microsoft Copilot was introduced into the sales process to enhance the efficiency of employees.
 - Efficiency ↑
 - Risk – Data privacy ; Dependence on AI affects judgment.
- Killer risk
 - Code space (similar to Github) 2014
 - Hackers gained access to Code Spaces' AWS control panel and launched a ransom attack.
 - When the company attempted to regain control, the attackers deleted nearly all data and backups.
 - no offline backups
 - no disaster recovery plan.
 - shutdown of its operations
- Other perils
 - Gitlab 2017 Database deletion by mistake
 - No backup
 - User data loss

- Reputation
 - The platform was forced to go offline for emergency maintenance
 - Cross functional risk
 - LY Corporation
 - Large-scale IT system migration project
 - The data engineering team failed to synchronize the field changes with the product team, resulting in the new system being unable to recognize the old data format.
 - The backend team updated the API, but the front-end team didn't receive the notification, resulting in abnormal functions.
 - Jingdong – logistic👍 – compare to Taobao – 用户更加信任 – reputation👍 – logistics & platform – Cross functional
 - Business process Unique risk
 - The SAP procurement approval process **for Indian railway suppliers**
 - Highly customized business processes
 - [Purchasing Document Approval Process with Manual Approver Selection Development](#)
-

External Environment:

1.Competitors: Google DeepMind(Gemini); Deepseek; 字节跳动(豆包)

2.Legal & regulatory loss: Copyright Infringement – used their copyrighted works without permission to train its language models; misuse of open-source code and violate software licenses. // Regulation –monopoly? bias?

3.Customer expectation: Ability to generate(easy to use, fast,accuracy,readable,interface user-friendly); free;

Business strategy & policies:

- Strategy & innovation: Model is not stable and they can't control. They even don't know about the inner logic inside the modeling training – how the result generated.
- Capital allocation: money allocate(Technique/investment/salary/shareholder)

Business Process Execution:

- Privacy – AI training using data – data misuse and privacy violation

- Knowledge/intellectual capital – the gap of people who have the specific knowledge and technique
- New technology – trend – how do they adopt the technology? catch up the trend

People

- Bad leadership
- Bad communication

Analysis & Reporting

Technology & Data

- Infrastructure– hashrate – specialized hardware (like GPUs and TPUs for parallel processing, fast storage, and high–speed networking)
- Technology reliability – whether or not their model use the real data instead of the fake data and the data they generate is reliable